Octobre 2026

Rapport de TP

Deploiement et analyse de Suricata IDS sur OPNsense

Pape Aldiouma SARR
L2 Cybersecurite - Module : Securite Reseau

Rapport de travaux pratiques : integration et configuration de Suricata IDS sur OPNsense, activation de regles de detection, tests d'attaque controles depuis Kali Linux et analyse des journaux EVE JSON.



Republique du Senegal, Un Peuple, Un But, Une Foi
Ministere de l'Enseignement Superieur, de la Recherche et de l'Innovation
Direction Generale de l'Enseignement Superieur Prive
Institut Superieur de Management
Annee academique 2025-2026

Table des matieres

Introduction..... 3
I. Configuration de Suricata IDS sur OPNsense..... 3
II. Telechargement et activation des regles de detection..... 5
III. Planification des mises a jour automatiques..... 6
IV. Verification du demarrage de Suricata..... 7
V. Tests d'attaques depuis Kali Linux..... 8
VI. Analyse des alertes dans OPNsense..... 12
VII. Tableau de validation..... 13
VIII. Mini-defi..... 14
IX. Guide de depannage..... 15
Synthese et conclusion..... 16

Introduction

Ce rapport documente le deploiement et le test du moteur de detection d'intrusion (IDS) Suricata, integre nativement a OPNsense. L'objectif est de configurer Suricata en mode detection pure sur l'interface LAN, d'activer des jeux de regles communautaires, puis de generer des attaques controlees depuis Kali Linux afin d'observer la reaction du systeme et d'analyser les journaux produits.

Environnement : QEMU/KVM, OPNsense (pare-feu et IDS), Debian Server (cible Apache/SSH), Debian Cliente (poste d'administration), Kali Linux (poste d'attaque). Reseau de laboratoire isole, plage 192.168.20.0/24.

I. Configuration de Suricata IDS sur OPNsense

Depuis Debian Cliente, ouvrir Firefox et naviguer vers https://192.168.20.1. Se connecter avec les identifiants definis lors de l'installation d'OPNsense (root / mot de passe).

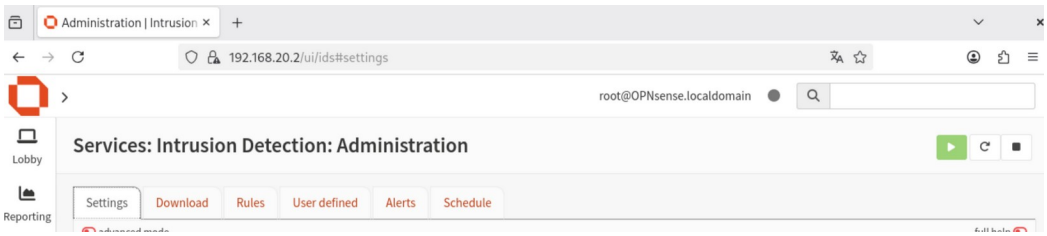
> *Suricata est deja integre dans OPNsense : aucune installation de plugin supplementaire n'est necessaire.*

1. Acceder au module Intrusion Detection

Navigation : Services -> Intrusion Detection

La page Administration s'ouvre. Les onglets en haut de page permettent de naviguer entre les differentes fonctionnalites :

Onglet	Role
Administration	Configuration generale (Settings) et statut du service
Download	Telecharger et activer les jeux de regles
Rules	Voir, rechercher et modifier les regles individuelles
Policy	Politiques globales de detection
User Defined	Creer ses propres regles Suricata
Alerts	Alertes generees en temps reel
Schedule	Planifier les mises a jour automatiques



Onglets du module Intrusion Detection dans OPNsense.

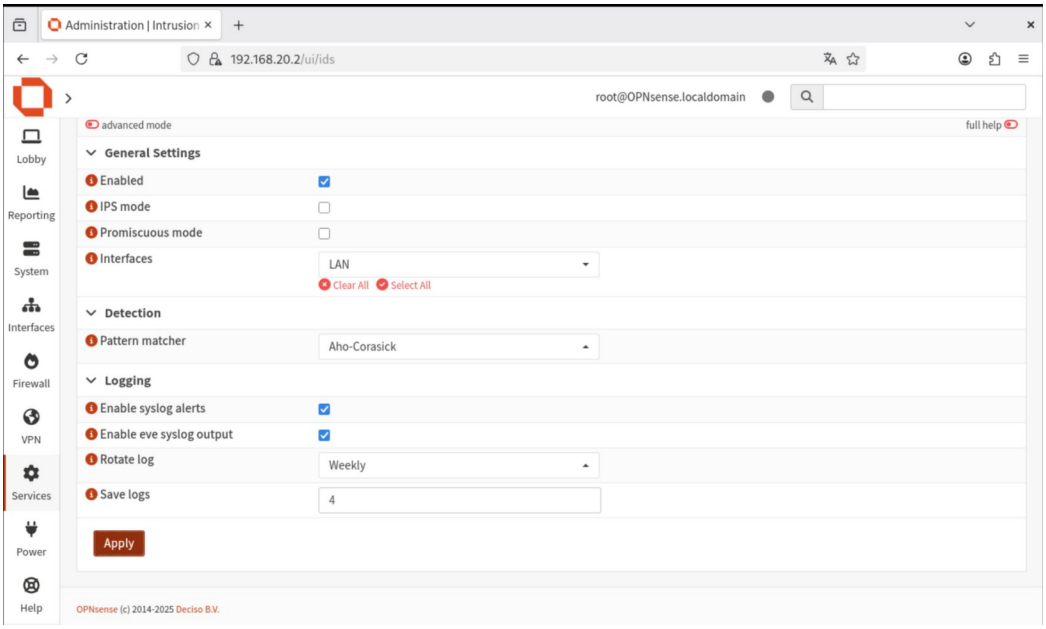
2. Onglet Administration : configurer les Settings

Remplir exactement les champs suivants, puis cliquer sur Apply :

Champ	Valeur a selectionner	Explication
Enabled	Coche (Yes)	Active le moteur Suricata
Capture mode	PCAP live mode (IDS)	Copie du trafic : detection seule, aucun blocage
Promiscuous mode	Decoche	Non necessaire ici (pas de VLAN sur l'interface)
Enable syslog alerts	Coche	Envoie les alertes dans le journal systeme OPNsense
Enable eve syslog	Coche	Active le format de log EVE JSON (structure)
Pattern matcher	Aho-Corasick	Compatible AMD et Intel, valeur universelle
Interfaces	LAN	Surveille l'interface interne (IP .20 / .50 / .99 visibles)
Rotate log	Weekly	Rotation hebdomadaire des fichiers de log
Save logs	4	Conserve 4 semaines d'historique

Pourquoi surveiller le LAN plutot que le WAN ? Sur le WAN, le NAT masque les vraies IP internes : Suricata ne verrait que l'IP externe d'OPNsense. Sur le LAN (192.168.20.0/24), les adresses de Kali (.99), Debian Server (.20) et Debian Cliente (.50) sont visibles et exploitables dans les alertes.

Cliquer sur Apply en bas de la page.



Parametres Suricata appliques dans l'onglet Administration.

II. Telechargement et activation des regles de detection

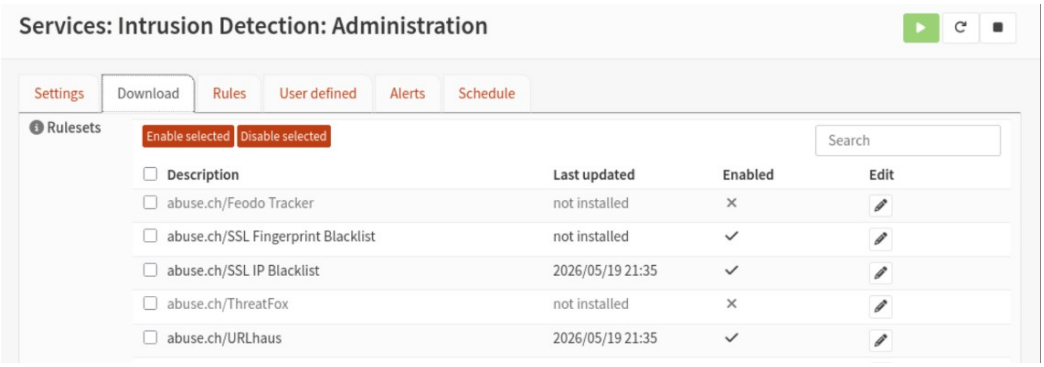
Sans regles, Suricata est actif mais aveugle. Cliquer sur l'onglet Download.

1. Jeux de regles disponibles

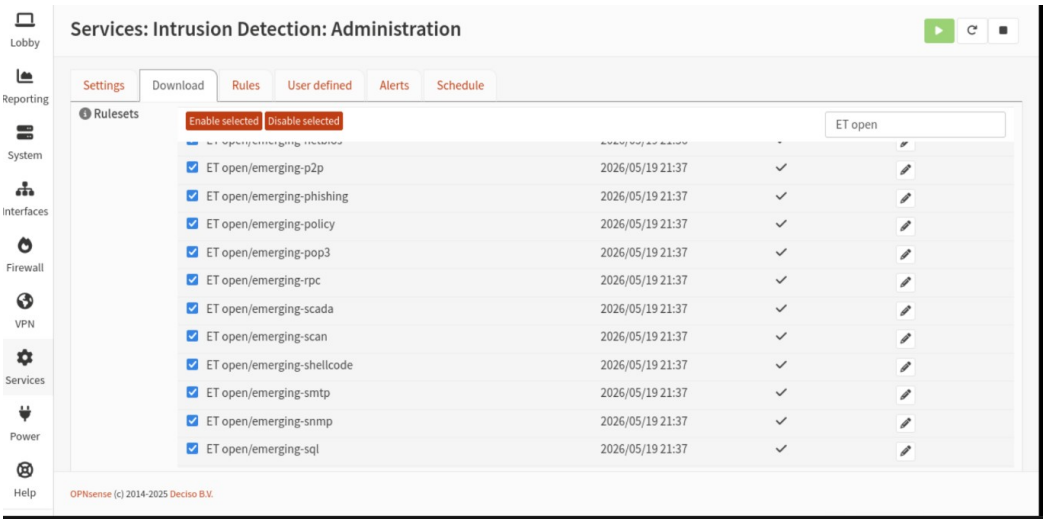
Nom	Gratuit	Description
ET Open (Emerging Threats)	Oui	Regles communautaires open-source, mises a jour quotidiennes
Abuse.ch SSL Blacklist	Oui	Certificats SSL lies a des malwares et botnets
Abuse.ch URLhaus	Oui	URL connues pour distribuer des malwares
Abuse.ch Feodo Tracker	Oui	Serveurs C2 du trojan Feodo / Emotet / Dridex
ET Pro Telemetry	Oui (compte requis)	Version pro avec couverture etendue et telemetrie anonyme

2. Activer et telecharger les regles

- Dans l'onglet Download, cocher les cases de : ET Open, Abuse.ch SSL Blacklist, Abuse.ch URLhaus.
- Cliquer sur Enable selected : les 3 jeux passent au statut Enabled.
- Cliquer sur Download and Update Rules.
- Attendre la fin du telechargement (environ 3 a 5 minutes selon la connexion d'OPNsense).



Jeux de regles selectionnes et actives dans l'onglet Download.

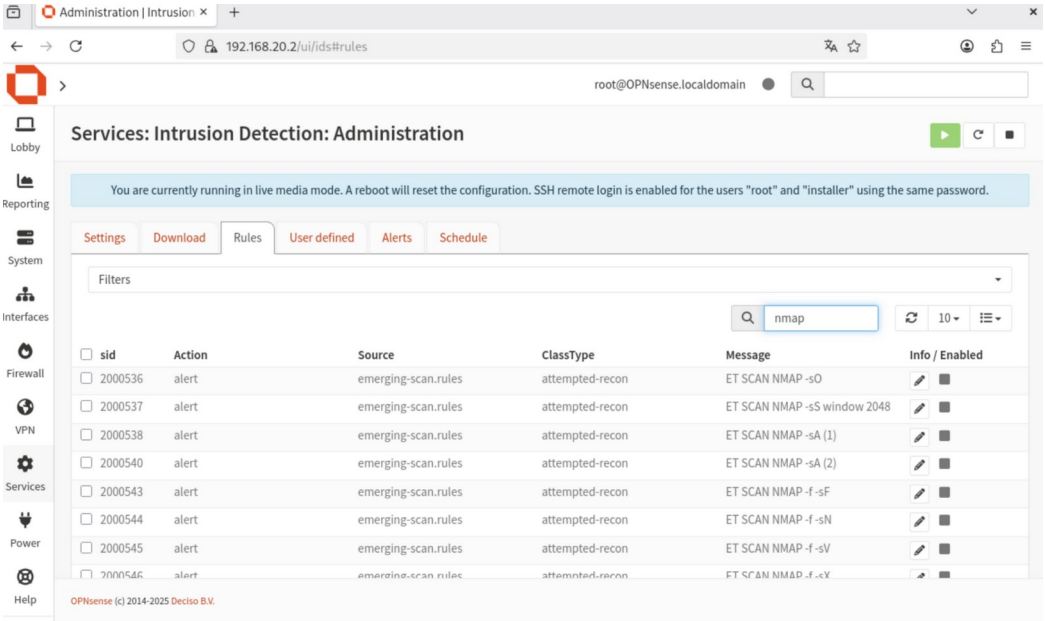


Telechargement et mise a jour des regles en cours.

3. Verifier dans l'onglet Rules

Cliquer sur Rules puis taper "nmap" dans la barre de recherche. Resultats attendus :

- ET SCAN NMAP -sV Version Scan
- ET SCAN NMAP Scripting Engine User-Agent Detected
- ET SCAN Possible NMAP Scan



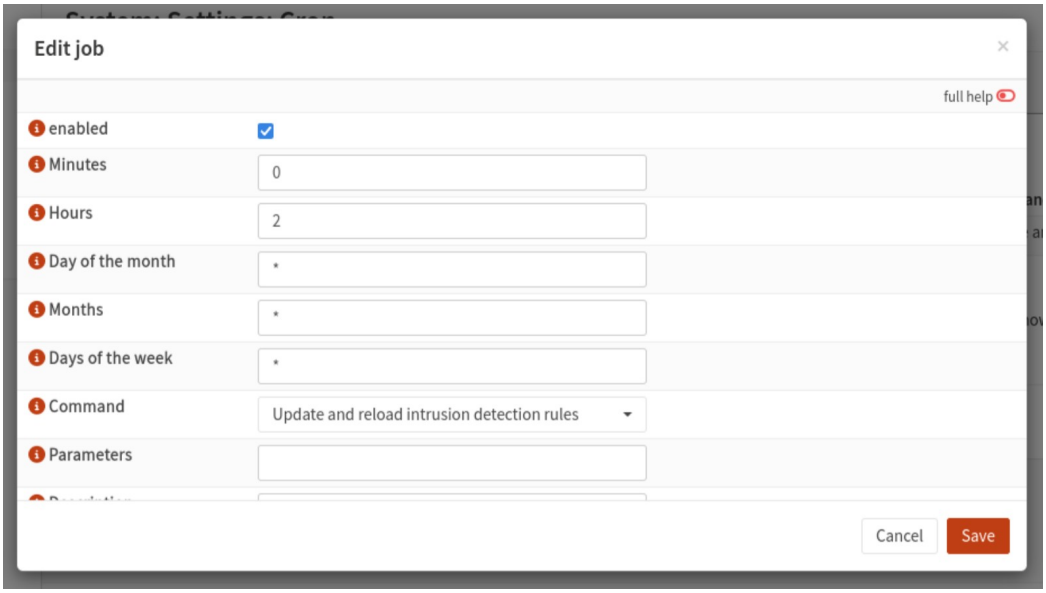
Recherche des regles liees a Nmap dans l'onglet Rules.

III. Planification des mises a jour automatiques

Cliquer sur l'onglet Schedule : il redirige automatiquement vers System -> Settings -> Cron avec un formulaire pre-rempli.

Champ	Valeur	Signification
Enabled	Coche	Active la tache planifiee
Minutes	0	A la minute 0
Hours	2	A 2h du matin
Day of month	*	Tous les jours du mois
Months	*	Tous les mois
Day of week	*	Tous les jours de la semaine
Command	(pre-rempli automatiquement)	Ne pas modifier
Description	Mise a jour regles IDS Suricata	Description libre

Cliquer sur Save, puis retourner dans Services -> Intrusion Detection pour confirmer.



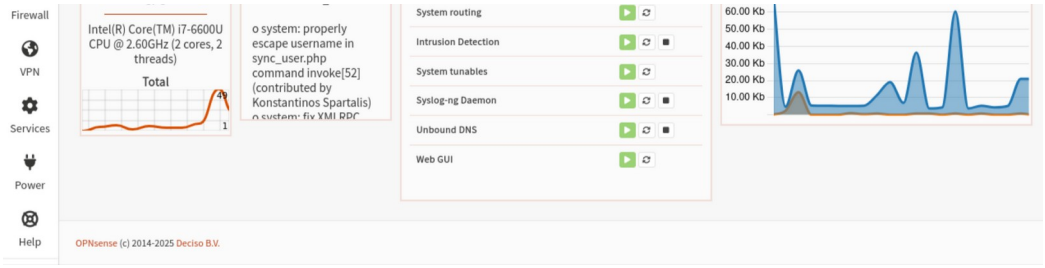
Planification Cron de la mise a jour quotidienne des regles.

IV. Verification du demarrage de Suricata

1. Verifier le statut du service

Depuis Debian Cliente (Firefox sur OPNsense) : Lobby -> Dashboard -> widget Services.

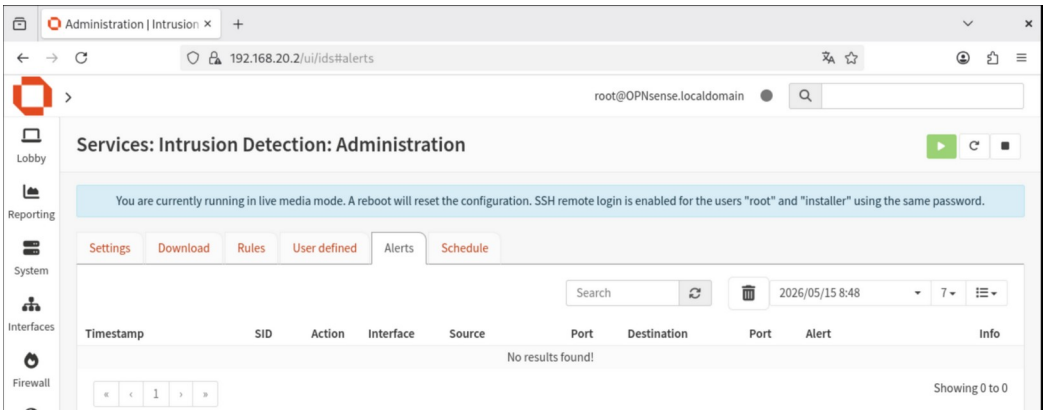
Suricata doit apparaitre avec le statut Running (vert).



Widget Services du tableau de bord OPNsense : Suricata en cours d'execution.

2. Verifier l'onglet Alerts

Cliquer sur Services -> Intrusion Detection -> Alerts. La page est vide, ce qui est normal a ce stade : elle se remplira lors des tests de la section suivante.



Onglet Alerts vide avant le lancement des tests d'attaque.

V. Tests d'attaques depuis Kali Linux

Rappel ethique : toutes ces attaques sont realisees dans un reseau QEMU/KVM completement isole, a des fins pedagogiques exclusivement. Ne jamais reproduire ces techniques sur des systemes reels sans autorisation ecrite explicite.

Organisation de l'espace de travail : une premiere fenetre sur Debian Cliente (Firefox, https://192.168.20.2, Services -> Intrusion Detection -> Alerts, rafraichie avec F5 apres chaque test) et une seconde fenetre sur Kali Linux (terminal pour lancer les attaques).

Pourquoi les alertes peuvent ne pas s'afficher en virtualisation

Lors des tests d'attaque depuis Kali, il est possible de ne voir aucune alerte dans l'onglet Alerts d'OPNsense. Ce n'est pas une erreur de configuration : c'est un comportement attendu lie a l'architecture virtualisee.

Explication technique :

- Suricata est configure en mode PCAP live sur l'interface LAN d'OPNsense (vtnet1).
- Dans un environnement QEMU/KVM avec un reseau virtuel isole (lab-net en mode Isolated), le trafic entre les VM est commute directement au niveau de l'hyperviseur, via le bridge virtuel Linux (virbr1).
- Ce trafic interne (Kali vers Debian Server) peut ne pas traverser physiquement l'interface LAN d'OPNsense, mais etre route directement par le bridge virtuel de l'hote Ubuntu.
- Consequence : Suricata en mode PCAP ne voit pas ce trafic, car ses paquets n'apparaissent pas sur l'interface vtnet1 d'OPNsense, ils restent dans le plan de commutation de l'hyperviseur.

Ce que cela signifie pour le TP :

- L'absence d'alertes ne signifie pas que Suricata est mal configure, mais que le trafic d'attaque ne transite pas par le point d'observation choisi (interface LAN d'OPNsense).
- En environnement reel, sur une infrastructure physique ou un hyperviseur correctement configure, tout le trafic passerait par OPNsense et Suricata generait bien les alertes attendues.

Constat supplementaire : disponibilite de la cible pendant les tests

Au-dela de la question de topologie reseau exposee ci-dessus, les sorties de commande capturees pendant les tests montrent une seconde cause, independante de Suricata, a l'absence d'alertes :

- Lors du Ping Sweep (Test 1), seule l'adresse 192.168.20.1 (OPNsense) a repondu aux requetes ICMP sur l'ensemble du sous-reseau scanne ; Debian Server (192.168.20.20) n'a pas repondu.
- Consequence directe : les Tests 2 et 3 (nmap -sS et -sV -A, sans l'option -Pn) ont chacun conclu "Host seems down ... 0 hosts up" et n'ont donc pas envoye de paquets de scan reels vers Debian Server.
- Le Test 4 (Hydra) a renvoye "could not connect to ssh://192.168.20.20:22 - Connection refused", ce qui indique que le service SSH n'etait pas joignable sur Debian Server a ce moment.
- Le Test 6 (curl, SQLi/XSS/traversee de repertoire) a renvoye "Failed to connect to 192.168.20.20 port 80 ... Could not connect to server" sur chacune des quatre requetes, indiquant qu'Apache n'etait pas non plus joignable.
- Le Test 7 a ete execute depuis Kali Linux vers sa propre adresse (nc 192.168.20.99 4444, lance depuis un terminal Kali) plutot que depuis Debian Server vers Kali comme le decrit la procedure, et s'est egalement solde par "Connection refused".

Ce constat ne remet pas en cause la configuration de Suricata, documentee et verifiee plus haut (moteur actif, regles chargees, interface LAN surveillee). Il indique plutot que, durant cette session de tests, Debian Server n'etait pas pleinement joignable (service SSH et serveur Apache non repondants, machine ne repondant pas au ping), probablement parce que les services concernes etaient arretes ou que la VM n'etait pas completement demarree. Sans trafic reel atteignant la cible, Suricata n'avait rien a observer sur ces tests, independamment de la question du bridge virtuel. Seul le Ping Sweep (Test 1) a effectivement genere du trafic jusqu'a OPNsense.

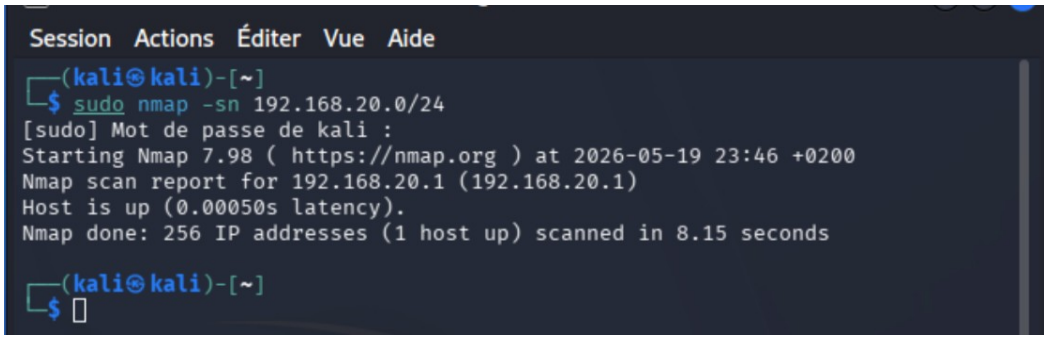
Test 1 : scan de reconnaissance Nmap (ping sweep)

Objectif : identifier les machines actives sur le reseau, premiere etape d'une attaque reelle.

```
sudo nmap -sn 192.168.20.0/24
```

Aller sur Debian Cliente, onglet Alerts, puis F5.

Alerte attendue	Signification
ET SCAN NMAP Ping Sweep	Balayage ICMP du reseau detecte
ET SCAN Potential Scan	Activite de scan generique detectee



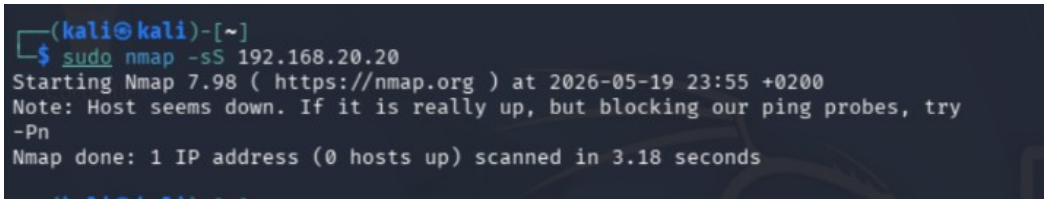
Resultat du ping sweep Nmap depuis Kali Linux.

Test 2 : scan SYN furtif

Objectif : identifier les ports ouverts sans etablir de connexion complete.

```
sudo nmap -sS 192.168.20.20
```

Alerte attendue	Signification
ET SCAN NMAP -sS Scan	Pattern de scan SYN Nmap identifie
ET SCAN SYN Scan Detected	Scan SYN generique detecte



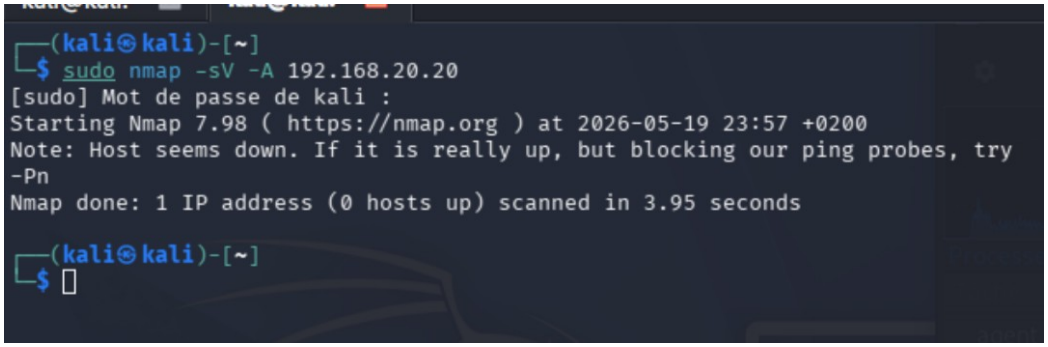
Resultat du scan SYN furtif.

Test 3 : scan de version agressif

Objectif : identifier les versions logicielles et le systeme d'exploitation de la cible.

```
sudo nmap -sV -A 192.168.20.20
```

Ce scan prend plus de temps : il utilise des scripts NSE.



Resultat du scan de version et de detection d'OS.

Test 4 : brute force SSH avec Hydra

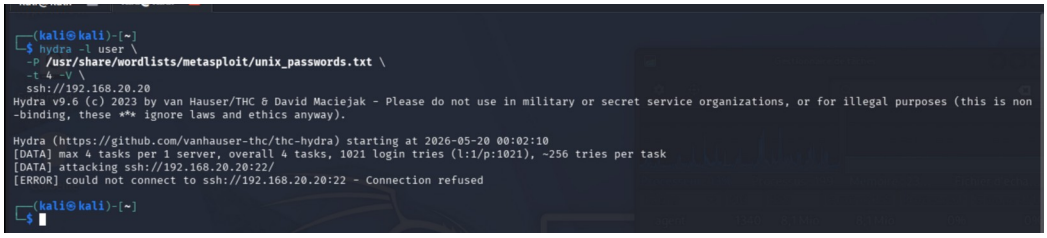
Objectif : simuler une tentative de devinette du mot de passe SSH.

Verifier d'abord que SSH ecoute sur Debian Server :

```
nc -zv 192.168.20.20 22
which hydra || sudo apt install -y hydra
```

```
hydra -l user \
  -P /usr/share/wordlists/metasploit/unix_passwords.txt \
  -t 4 -V \
  ssh://192.168.20.20
```

Alerte attendue	Signification
ET SCAN Potential SSH Scan OUTBOUND	Tentatives SSH repetees detectees
ET BRUTE SSH brute force attempt	Attaque brute force SSH caracterisee



Tentatives de connexion SSH par force brute via Hydra.

Test 5 : scan de vulnerabilites web (Nikto)

Objectif : identifier des vulnerabilites courantes sur le serveur Apache.

```
sudo apt install -y nikto
nikto -h http://192.168.20.20
```

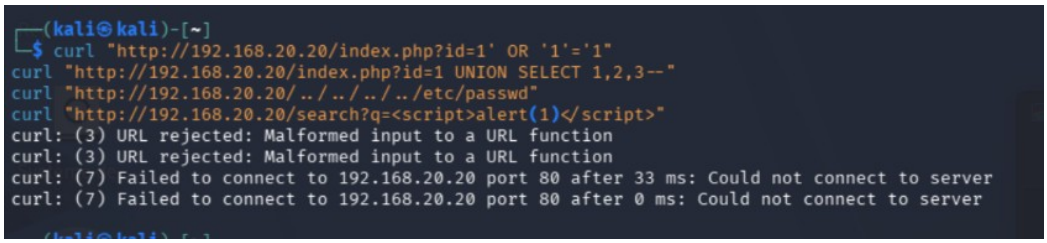
Alerte attendue	Signification
ET WEB_CLIENT Nikto Scanner User-Agent Detected	User-Agent de Nikto identifie dans les requetes HTTP
ET WEB_SERVER Possible SQL Injection Attempt	Requetes de type SQL generees par Nikto

Test 6 : injections SQL, XSS et parcours de repertoire

Objectif : simuler des requetes HTTP malveillantes ciblant Apache sur Debian Server.

```
curl "http://192.168.20.20/index.php?id=1' OR '1'='1"
curl "http://192.168.20.20/index.php?id=1 UNION SELECT 1,2,3--"
curl "http://192.168.20.20/../../../../etc/passwd"
curl "http://192.168.20.20/search?q=%3Cscript%3Ealert(1)%3C/script%3E"
```

Alerte attendue	Type d'attaque
ET WEB_SERVER Possible SQL Injection Attempt	Injection SQL dans un parametre d'URL
ET WEB_SERVER Directory Traversal Attempt	Traversee de repertoire vers /etc/passwd
ET WEB_SERVER Cross-Site Scripting Attempt	Injection de script JavaScript dans un parametre d'URL



Requetes HTTP malveillantes (SQLi, XSS, traversee de repertoire) envoyees vers Apache.

Test 7 : simulation de trafic C2 (Command & Control)

Objectif : simuler une machine compromise (Debian Server) contactant un serveur C2 (Kali).

Depuis Kali Linux, terminal 1, demarrer l'ecouteur :

```
nc -lvp 4444
```

Depuis Kali, terminal 2, ouvrir une session SSH sur Debian Server :

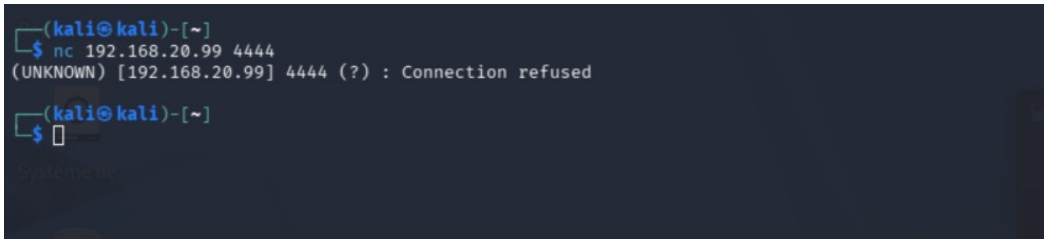
```
ssh user@192.168.20.20
```

Sur Debian Server, simuler la connexion vers le serveur C2 (Kali) :

```
nc 192.168.20.99 4444
```

Taper quelques messages, laisser 30 secondes puis Ctrl+C.

Alerte attendue	Signification
ET POLICY Suspicious Inbound to Port 4444	Port 4444 souvent utilise par Metasploit et autres C2
ET TROJAN Possible C2 Connection	Connexion correspondant a un pattern de trojan C2

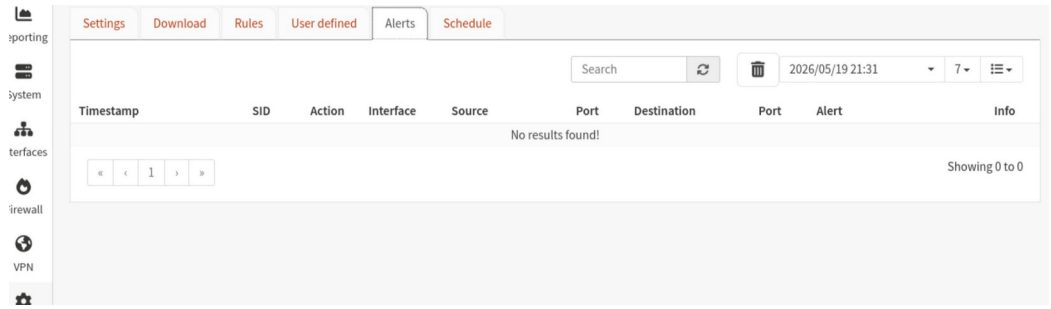


Session netcat simulant une connexion vers un serveur de commande et controle.

VI. Analyse des alertes dans OPNsense

1. Lire l'onglet Alerts (depuis Debian Cliente)

Depuis Debian Cliente, Firefox, https://192.168.20.2, Services -> Intrusion Detection -> Alerts : aucune alerte n'est visible a ce niveau, pour les raisons techniques expliquees a la section V.



Onglet Alerts d'OPNsense apres l'ensemble des tests.

2. Lire les logs EVE JSON

Depuis OPNsense : System -> Diagnostics -> Execute command.

```
tail -20 /var/log/suricata/eve.json | grep '"event_type":"alert"'
grep '192.168.20.99' /var/log/suricata/eve.json | grep '"event_type":"alert"' | tail -10
tail -1 /var/log/suricata/eve.json | python3 -m json.tool
```

Structure d'une alerte EVE JSON, commentee :

```
{
  "timestamp": "2026-01-15T14:23:05.123456+0000",
  "event_type": "alert",
  "src_ip": "192.168.20.99",      // Kali Linux (attaquant)
  "src_port": 54321,
  "dest_ip": "192.168.20.20",     // Debian Server (cible)
  "dest_port": 22,                 // port SSH
  "proto": "TCP",
  "alert": {
    "action": "allowed",          // IDS : le trafic n'est pas bloque
    "signature_id": 2001219,       // SID de la regle declenchee
    "signature": "ET SCAN Potential SSH Scan OUTBOUND",
    "category": "Attempted Information Leak",
    "severity": 2                  // gravite : 2 = majeur
  }
}
```

"action": "allowed" confirme le mode IDS. En mode IPS (Netmap ou Divert), cette valeur deviendrait "blocked" ou "drop" et le paquet serait reellement arrete avant d'atteindre la cible.

VII. Tableau de validation

Synthese des tests realises. Aucune alerte n'a ete visible dans l'onglet Alerts d'OPNsense sur l'ensemble des tests, pour deux raisons cumulees detaillees a la section V : le trafic entre Kali et Debian Server transite par le bridge virtuel de l'hyperviseur sans passer par l'interface LAN surveillee, et Debian Server n'etait pas pleinement joignable (ICMP, SSH et HTTP) durant une partie de la session de tests.

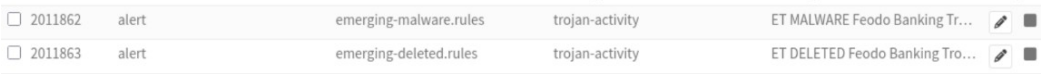
Test	Commande (Kali)	IP source	Port dest.	Alerte observee
Ping Sweep	nmap -sn 192.168.20.0/24	192.168.20.99	-	Aucune ; seul OPNsense (.1) a repondu
SYN Scan	nmap -sS 192.168.20.20	192.168.20.99	variable	Aucune ; cible signalee hors ligne (0 host up)
Scan de version	nmap -sV -A 192.168.20.20	192.168.20.99	variable	Aucune ; cible signalee hors ligne (0 host up)
Brute force SSH	hydra ... ssh://192.168.20.20	192.168.20.99	22	Aucune ; SSH Connection refused
Nikto	nikto -h http://192.168.20.20	192.168.20.99	80	Aucune ; pas de capture disponible pour confirmer la joignabilite
Injection SQL / XSS / traversee	curl ...?id=1' OR '1'='1 (et autres)	192.168.20.99	80	Aucune ; HTTP Could not connect to server
Trafic C2	nc 192.168.20.99 4444 (execute depuis Kali)	192.168.20.99	4444	Aucune ; Connection refused, test non conforme a la procedure (voir section V)

VIII. Mini-defi

Defi 1 : activer les regles Feodo Tracker (Emotet / Dridex)

Le responsable SOC demande d'ajouter la detection des serveurs C2 du trojan bancaire Feodo :

- Services -> Intrusion Detection -> Download
- Rechercher "Feodo" dans la liste
- Cocher la case, puis Enable selected, puis Download and Update Rules
- Verifier dans l'onglet Rules (recherche "feodo") que les regles sont bien presentes



Jeu de regles Feodo Tracker active dans l'onglet Download.

Defi 2 : documenter une regle Suricata

Cette partie du defi n'a pas pu etre completee en l'etat : comme expose a la section V, aucune alerte n'a ete generee dans l'onglet Alerts en raison du contournement du point d'observation (le trafic inter-VM ne traverse pas l'interface LAN surveillee par Suricata

dans cette topologie virtualisee). Il n'y avait donc pas d'alerte concrete a partir de laquelle retrouver une regle par son SID et documenter ses champs.

Pour completer cet exercice, deux approches sont possibles : forcer le trafic a traverser l'interface LAN d'OPNsense (par exemple en placant Suricata en coupure sur le lien physique plutot que sur un bridge interne a l'hyperviseur), ou analyser directement une regle depuis l'onglet Rules (par exemple la regle ET SCAN Potential SSH Scan OUTBOUND) sans attendre qu'elle se declenche, afin d'en documenter la structure a titre d'exemple.

IX. Guide de depannage

Probleme observe	Cause probable	Solution
kvm-ok : cannot be used	VT-x/AMD-V desactive dans le BIOS	Redemarrer, activer dans le BIOS (F2/F10/Suppr)
OPNsense sans IP WAN	NIC 1 non connectee au reseau default	Verifier dans Virt-Manager, VM opnsense-lab, NIC 1
VM ne se pinguent pas	IP mal configuree ou reseau lab-net incorrect	ip addr show sur chaque VM, verifier virsh net-list
apt update echoue sur Debian	Pas de DNS, OPNsense pas demarre	Demarrer OPNsense en premier, verifier la passerelle 192.168.20.1
Telechargement des regles echoue	OPNsense sans acces Internet	Console OPNsense : ping 8.8.8.8, verifier la NIC WAN
Aucune alerte dans Alerts	Interface LAN non selectionnee ou Suricata arrete	Verifier Settings, Interface = LAN, cliquer sur Apply
Apache ne repond pas	Service arrete sur Debian Server	systemctl start apache2 sur Debian Server
SSH refuse	Service arrete ou pare-feu actif	systemctl start ssh ; verifier ufw status sur Debian Server
Firefox n'affiche pas OPNsense	IP Cliente mal configuree ou OPNsense arrete	ip addr sur Debian Cliente, ping 192.168.20.1

Commandes de diagnostic rapide

Sur l'hote Ubuntu :

```
virsh list --all              # etat de toutes les VM
virsh net-list --all          # reseaux virtuels (default + lab-net)
virsh domiflist opnsense-lab  # verifier les 2 NIC d'OPNsense
```

Sur OPNsense :

```
ifconfig                                # interfaces et IP
ping 8.8.8.8                            # test Internet
tail -20 /var/log/suricata/eve.json     # dernieres alertes JSON
```

Sur Debian Server :

```
ip addr show                   # IP configuree
```

```
systemctl status apache2 ssh   # services actifs
```

Sur Kali Linux :

```
ip addr show && ip route show   # IP .99 et route par defaut via .1
curl -v http://192.168.20.20    # Apache de Debian Server accessible ?
```

Synthese et conclusion

Ce qui a ete mis en place

- QEMU/KVM sur Ubuntu, avec un reseau virtuel isole lab-net (192.168.20.0/24).
- OPNsense (192.168.20.1) : pare-feu et Suricata IDS en mode PCAP live (detection seule).
- Debian Server (192.168.20.20) : cible avec Apache et SSH, attaquee depuis Kali.
- Debian Cliente (192.168.20.50) : poste d'observation avec GNOME et Firefox sur la WebGUI d'OPNsense.
- Kali Linux (192.168.20.99) : poste d'attaque avec Nmap, Hydra, Nikto, curl, netcat.
- Regles ET Open et Abuse.ch telechargees, activees, avec mise a jour automatique configuree a 2h du matin.

Questions de comprehension

1. Pourquoi OPNsense surveille-t-il l'interface LAN plutot que le WAN ?

OPNsense surveille l'interface LAN plutot que le WAN pour des raisons de fiabilite de supervision : le but est de verifier si le pare-feu lui-meme et le reseau interne sont fonctionnels, et pas seulement si Internet est joignable. Sur le WAN, le NAT masque de plus les adresses internes reelles.

2. Quelle est la difference concrete entre IDS (PCAP live) et IPS (Netmap/Divert) ?

Un IDS observe le trafic, le journalise et genere des alertes, sans intervenir sur les paquets. Un IPS, place en coupure sur le flux, peut en plus bloquer ou abandonner activement un paquet identifie comme malveillant avant qu'il n'atteigne sa cible.

3. Que signifie "action": "allowed" dans un log EVE JSON ?

Cela signifie que Suricata a detecte l'activite correspondant a une signature et l'a journalisee, mais a laisse le paquet poursuivre son chemin sans le bloquer : c'est le comportement normal et attendu du mode IDS.

4. Pourquoi les mises a jour automatiques quotidiennes des regles sont-elles essentielles en production ?

De nouvelles menaces et de nouveaux indicateurs de compromission apparaissent en permanence. Sans mise a jour reguliere des jeux de regles, Suricata continue de fonctionner avec une base de signatures obsolete et devient incapable de detecter les campagnes d'attaque recentes.